

## The Culture of Cybersecurity. With Security Incidents, the Blame is Often More Ours than the Technology

Intervention by Guido Scorza, Member of the Guarantor for the Protection of Personal Data (StartupItalia, November 27, 2023)

Around the world, 77% of companies have experienced cybersecurity incidents in the last two years. So far, there is no surprise in the results of a study conducted by Kaspersky in 19 countries and published last week. Less expected—although, in this case, not surprising at least for industry insiders—is the other data that emerges from the same research: in 64% of cases, the human factor was at the origin of the incident. However, it is by continuing to read the data that emerges from the report by the cybersecurity company that one likely encounters some more interesting conclusions. In 26% of cases, in fact, the origin of the incident is a conscious violation of a company policy by an employee who simply ignored or, at least, underestimated its importance, considering it an unnecessary formality or perhaps prioritizing their own selfish interest to act quickly, to do things their own way, to achieve a personal result deemed more important than the collective one of their organization, their colleagues, and/or the clients and suppliers of their company.

Certainly, if one were to start from the assumption that a company policy regarding cybersecurity is a more or less minimal but nonetheless essential set of rules to be followed if one cares about the assets of their company, its reputation, and the trust relationship between it and its clientele, and if these values were prioritized over selfish interests, it is likely that such numbers regarding incidents caused by intentional violations of policies would not be recorded. The selfishness of individual employees and/or their technological illiteracy, which likely leads them to underestimate the importance of cybersecurity, however, is not, according to Kaspersky's research, the only human factor behind a significant number of cybersecurity incidents. Another significant factor—which perhaps surprises more than the previous one—is the all-too-human error of the information systems and cybersecurity managers with greater seniority, those who, in short, should know better. According to the research, in 15% of cases, the blame would be attributed to them. Of course, the numbers are the result of a survey largely based on the statements of individuals directly involved in the events they describe, and therefore, it is not said that the percentages reflect the reality of the facts to the cent, but it is difficult to doubt the reliability of the trend and the description of the phenomenon. On the other hand, the lack of adequate skills in the field of cybersecurity is, for 75% of the interviewed companies, at the origin of the incidents suffered. In short, in most cases, there is an awareness of not knowing enough. Then, of course, as is often the case in these matters, the world is divided in half: 28% of companies believe it is possible to do better but lack adequate resources, while exactly the same percentage is convinced that they have everything necessary to feel cyber-secure.

Continuing to hunt for the most interesting data in a study rich with numbers useful for suggesting reflections in different directions, and in this sense, probably worth reading regardless of this summary, it is striking that the telecommunications industry is the most frequent victim of cybersecurity incidents. Of course, there is no surprise that it is a sector more exposed than others to cyber-attacks and consequently may also fall victim more frequently. However, the data that is somewhat more surprising is that of incidents due to the human factor as represented thus far in a sector that has one of the lowest average ages of the workforce, with 66% of workers under 35 years old, a demographic in which one would expect—perhaps mistakenly—a greater sensitivity to cybersecurity and a more widespread technological competence. But whether the cause of the incident is one or the other, whether the human factor weighs a bit more or a bit less, there is a constant or, at least, a more relevant data than others: the consequences of the incident are always significant and at least one time out of three translate into a data breach, a violation of the privacy of employees and/or clients, resulting in reputational damage for the company, which is then, of course, exposed to potential sanctions for violations—where applicable—of the regulations regarding the protection of personal data. And here is the reason why we discuss it in this column.

Kaspersky's research, in fact, while more generally addressing cybersecurity incidents, provides a valuable snapshot of personal data violations and, therefore, on what to do—or at least try to do with

the firm awareness that security, in every field, is always a goal and rarely a result that can be fully achieved—to avert the risk of suffering them. The most important lesson to take home, probably, is that without adequate education on the value of cybersecurity and, in particular, for what concerns us most closely, the value of data, and without significant investment in the dissemination of adequate basic and advanced digital skills, it is unlikely that the best possible investments in infrastructure and technological services will be sufficient to keep companies and personal data safe because, indeed, as the study suggests without hesitation, the weak link remains us, the people. The full version of the report is available [here](#).